

Live presentation — preparation and rehearsal

Member 5 — ISSD | Companion to LIVE_DEMO and LIVE_COMMANDS

1. Use the finished files

Keep these together on the presentation laptop:

File	Use
MAIN_PRESENTATION.pptx	Present slides 1–8; slides 9–12 support questions and recovery
MAIN_PRESENTATION.pdf	Portable slide backup
LIVE_COMMANDS.pdf	Two-page terminal A/B command sheet
LIVE_DEMO.pdf	Full command order, expected output and recovery
SLIDE_NOTES.pdf	Explanations and terminal transition cues
REPORT.pdf	Full six-task report and labelled screenshot figures
evidence/	Original images to open if a live attempt misses

The older REPORT_TEMPLATE and PRESENTATION_PLAN files in the parent folder are preparation material. The completed work is in submission/. S15 is an earlier evidence-inventory capture; its statement that written submission work remained describes that earlier checkpoint.

2. Check the prepared VM before rehearsal

Start the **SEED Ubuntu 20.04 VM used for these experiments**. The Windows repository and the VM are separate copies: a Windows git pull does not update the guest. The retained cleanup evidence shows victims at 0755 and protections at 1/2; verify the actual current state when you boot.

In a guest terminal, as seed:

```
cd /home/seed/issd-member5/lab-files
id
command -v python3 gcc bash sha256sum pgrep
ls -l vulp vulp_slow vulp_least attack_naive attack_atomic
ls -l input.txt run_trials.sh ../passwd-before.sha256 ../sysctl-before.txt
ls -l ../automation/{reset.sh,audit-setup.sh,cleanup.sh}
ls -l ../automation/{lab_runner.py,verify-record.py}
test -d logs && test -w logs && echo 'Log directory is writable'
sudo test -f /root/issd-member5-passwd.original && echo 'Original backup exists'
```

Resolve missing-file errors before Part 0. The runner opens its log file before starting the attacker, so an absent logs/ directory must be created with `mkdir -p logs`. If binaries are missing, use the supplied `bash build.sh` inside the guest after ensuring previous trials have stopped. Rebuilding requires the documented ownership/Set-UID setup again.

If the guest helpers are missing

The original setup guide copies only the parent lab-files/ folder. The newer live guide also needs submission/automation/ and the audited submission/source/run_trials.sh. If the existing prepared guest already contains them, compare versions before replacing anything.

With the Windows Member5 folder shared as M5pack and mounted at ~/m5-transfer as described in START_TO_FINISH_GUIDE section 4.2, these paths should be readable inside the guest:

```
ls ~/m5-transfer/submission/automation
ls ~/m5-transfer/submission/source
```

For missing helpers only, copy without overwriting existing guest files:

```
mkdir -p ~/issd-member5/automation ~/issd-member5/lab-files/logs
cp -n ~/m5-transfer/submission/automation/* ~/issd-member5/automation/
sed -i 's/\r$//' ~/issd-member5/automation/*.sh
```

The guest monitor must be the audited version that retains interrupted totals and rejects reused labels. Compare it while ignoring Windows line endings:

```
diff -u <(sed 's/\r$//' ~/m5-transfer/submission/source/run_trials.sh) run_trials.sh
```

No diff output means the contents agree. If they differ, preserve the guest file and inspect the difference before replacing it; the final audited source is submission/source/run_trials.sh. The other C/build sources are also supplied there.

A fresh VM needs its own baseline. Follow START_TO_FINISH_GUIDE sections 3–6 to install, back up, build and validate Task 1. Never use the recorded passwd-before.sha256 from this submission as the baseline of a different VM. The root-owned original password-file backup is deliberately not distributed as an installation file. The classroom commands assume the documented seed account, path and validated input record.

The older setup guide reads the sysctl values without sudo. In the recorded guest those nodes required sudo, so use `sudo sysctl fs.protected_symlinks fs.protected_regular` when checking them. For the existing prepared VM, use LIVE_DEMO Part 4's explicitly selected final 1/2 policy; the historical guide's restore-from-file step would restore its saved 0/0 instead.

3. Arrange the display

1. Open A — Attacker on the left and B — Victim and results on the right, both as seed in the lab-files directory.
2. Increase terminal font size until commands and UID output are readable from the audience position. Prefer fewer visible lines to tiny whole-desktop text.
3. Keep LIVE_COMMANDS on paper or a separate presenter display. Keep the presentation and saved screenshot viewer ready to switch to.
4. Run LIVE_DEMO Part 0 in full. Confirm clean baseline, root-owned 4755 victims and controls 0/0. Show the vulnerable code while explaining slide 2, before launching the attack.
5. Prepare the short link-switch command in A so it can be entered promptly after B says Check passed. Do not execute it before that message.

4. Rehearse the full route

Slide	Explain / do	Check before moving on
1	Define a race and TOCTOU	Audience understands timing-dependent ordering
2	Show access/fopen; distinguish real UID 1000 and effective UID 0	Explain why the link grants no privilege by itself
3	LIVE_DEMO Part 1: explicit 10-second teaching window	Link switched after check; complete record; actual non-sudo login/id
4	Interpret the result; distinguish Task 1 manual insertion	Exit root and reset before another run
5	Explain recorded measurements; LIVE_DEMO Part 2 if time permits	Original no-delay vulp; unique label; attacker ready before monitor
6	Explain naive missing-name gap and atomic exchange	Atomic exchange repairs the attacker, not the victim

Slide	Explain / do	Check before moving on
7	Explain both independent defence trials; LIVE_DEMO Part 3 if time permits	Original victim with controls 1/0 for OS control
8	Explain impact, secure file handling, permissions and safe creation	Finish with the key lesson and cleanup

Run LIVE_DEMO Part 4 after **every** rehearsal and after the class demonstration. Record whether cleanup actually passed. A rehearsal is complete only after the explanations, terminal switching, login handling and cleanup have been practised together.

Keep the demonstration short

The lecturer asks for a short demonstration but supplies no exact time limit. Time your rehearsal against the group's actual allowance.

The core live segment is Part 1, followed by explanation of recorded no-delay and defence findings. If time permits, add the bounded Part 2 and the one-call Part 3 control. When skipping a live segment, state that slides 5 and 7 contain recorded results. All six tasks remain covered in the written report. The two 300-second trials do not need to be repeated during a short talk.

Do not interpret the 30-second monitor limit as the duration of the entire presentation: setup, explanation, authentication, resets and display switching also take time. After the atomic attacker announces readiness, start B promptly; A has a separate 90-second lifetime. If it expires first, stop/reset and start a new labelled trial.

5. Open the right fallback evidence

Live situation	Recorded evidence to open	What to say
Slow timing window missed	S06-task2a-timing.png and S07-task2a-result.png	This attempt missed; these are the earlier delayed demonstration and login result
No-delay run times out	S11-task2c-atomic-result.png; S09-task2b-result.png for the naive method	The new bounded attempt did not win; these labelled earlier runs did
Explain the sticky-file failure	S10a-task2b-sticky-bit.png and S10b-task2b-file-exists.png	Actual unlink denial and a distinct File-exists trial were preserved
Explain defences	S12a/S12b and S13a/S13b images	No change in the recorded finite trials, plus denied-operation and allowed-file controls

Use the report's enlarged figures or zoom the original image to the relevant terminal. The whole-desktop screenshots are evidence archives, not all suitable for projection at fit-to-screen size. Slide 9 already supplies enlarged S09 proof excerpts. S15 is optional inventory evidence, not a final-report or live-success screenshot.

6. Be ready to answer these questions

Question	Short answer
Why can seed change the link but not /etc/passwd?	The link is seed-controlled in /tmp. The privileged victim supplies authority to open the protected target.
Why is access() insufficient?	It checks with the real identity, then a separate lookup/open uses the effective identity; the pathname can resolve to a different object.
Why /dev/null first?	It is writable by seed, so the check can pass.
Why is test a root account?	Its UID is zero. The account name itself is not the privilege.

Question	Short answer
Was Task 1 an attack?	No. Administrator insertion validates the record; independent attacks follow a clean reset.
Is the ten-second run a real no-delay race?	No. It is the official teaching simulation. Tasks 2.B and 2.C use the separate no-delay binary.
Why did the naive attacker stop?	The unlink/create gap let the victim create a root-owned regular file; sticky /tmp prevented seed from deleting it.
Why use atomic exchange?	It swaps initialized links without leaving XYZ absent during switching. The victim still has separate check/use operations.
What does 0 seconds mean?	The Bash counter has whole-second granularity. The recorded runner wall time is nonzero and includes orchestration.
Why not claim atomic is always faster?	A few scheduling-dependent outcomes do not establish a general performance or success-rate comparison.
How do the defences differ?	Least privilege removes root authority during file work. Symlink protection denies this ownership/context-specific privileged traversal.
Do five minutes without success prove every race is fixed?	No. State the observed counts/time and explain the credential or pathname rule supporting the result.
What would you use in real code?	Appropriate privilege, trusted directories, secure exclusive temporary creation and descriptor-based operations on the opened object.

7. Final readiness record

The repository review is separate from a live rehearsal. Complete these yourself in the actual presentation environment:

- VM starts and the prerequisites above pass.
- Part 0 re-enables the demonstration after the previous cleanup.
- A/B timing, interactive login and return to seed are practised.
- Both the successful and missed/timeout explanation paths are familiar.
- Saved evidence and the PDF slide backup open without relying on a network connection.
- The segment fits the group's agreed time.
- Part 4 cleanup passes.
- The group confirms the deadline, final filename and upload format.